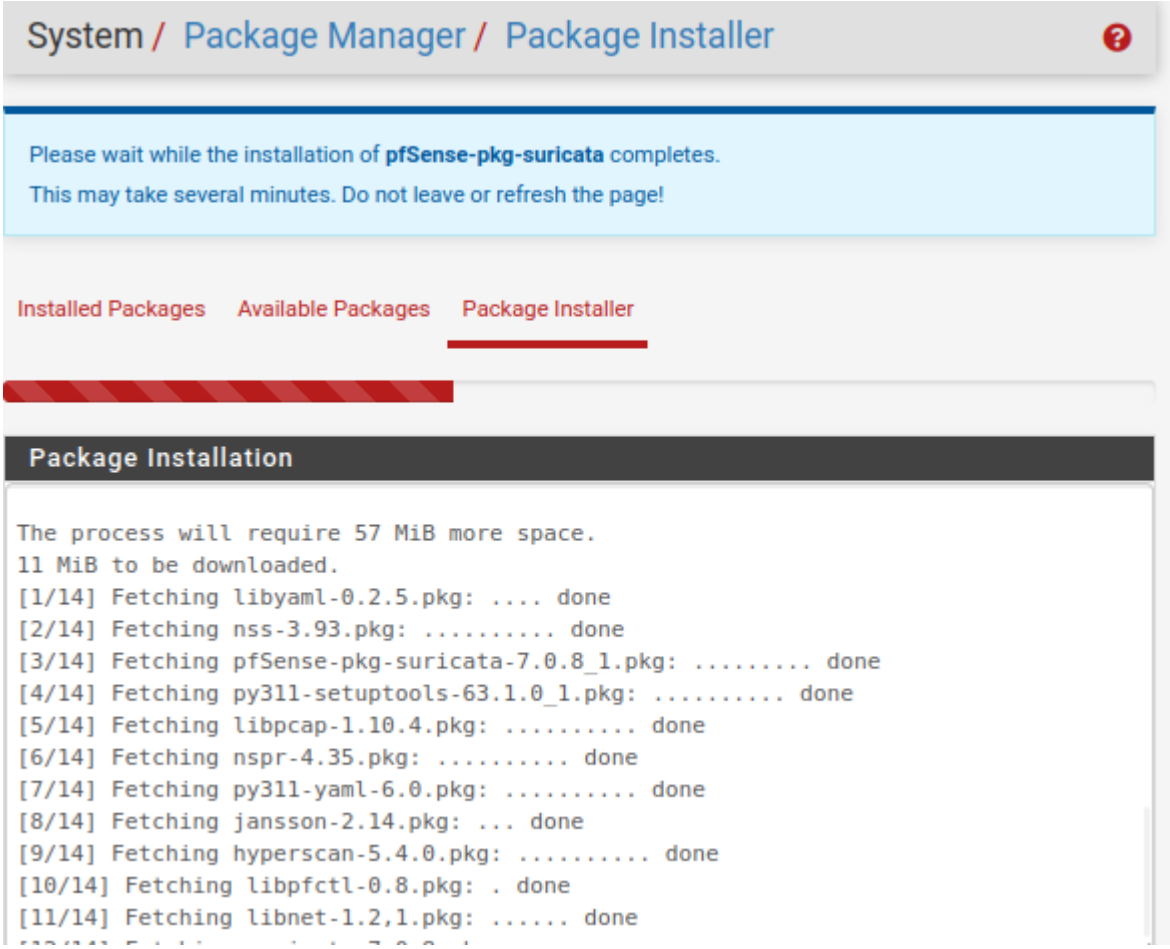
COMPTE RENDU DU TP 4.2

Détection d'attaques avec un IDS/IPS (Suricata sur pfSense)

1. Installation de Suricata sur pfSense

Connexion à l'interface pfSense via https://192.168.1.1, puis navigation vers :

System → Package Manager → Available Packages → rechercher « Suricata » → Install.



2. Activation de Suricata sur l'interface LAN

Après installation : Services → Suricata → Add → Interface : LAN → Enregistrer.

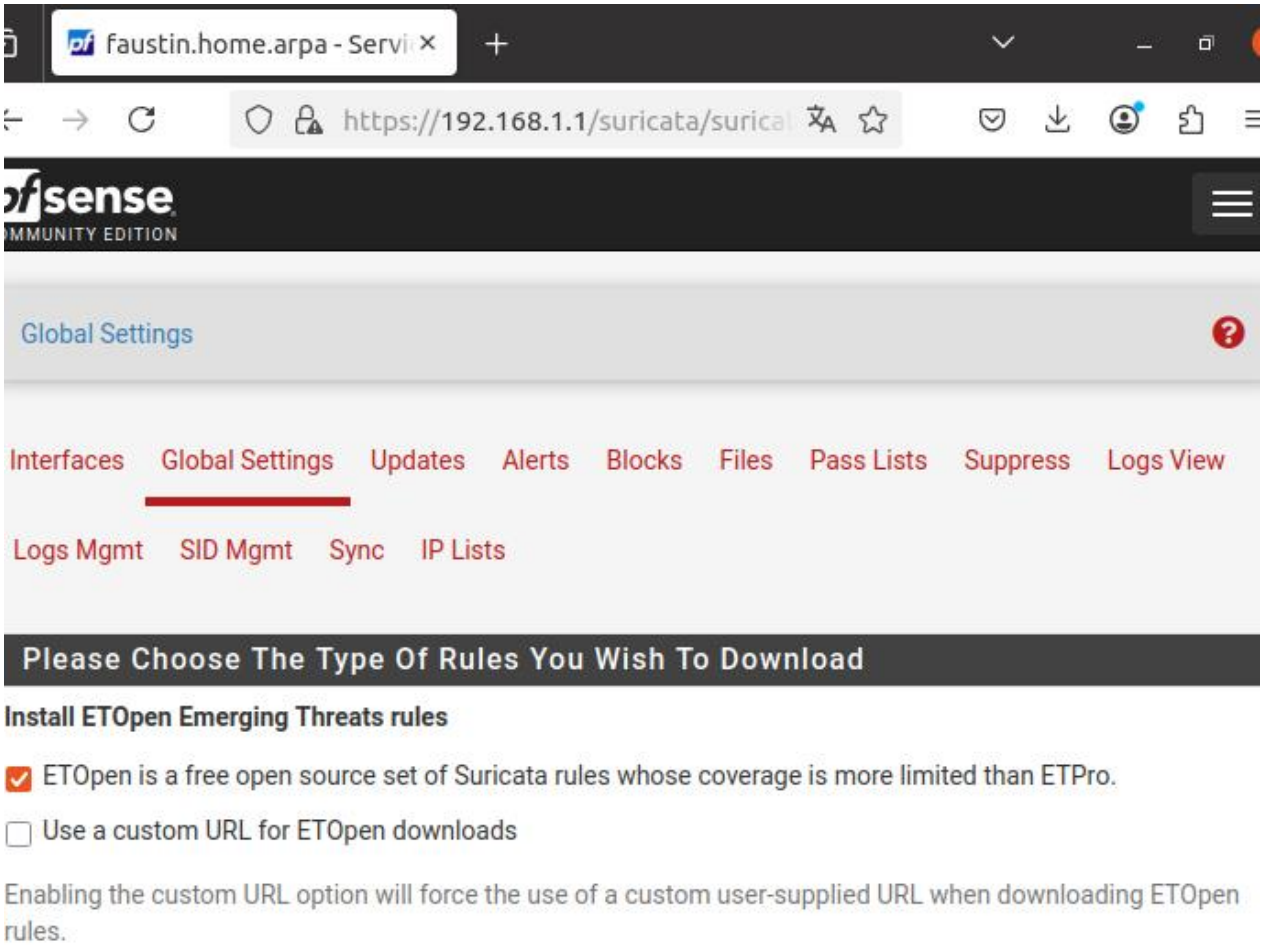
Le LAN est surveillé car la majorité des attaques se produisent en interne après une première compromission.

3. Activation des règles de détection

Dans Global Settings : activer « Enable ET Open Rules » (Emerging Threats Open).

Aller dans Updates → Update Rules pour télécharger la base de signatures.

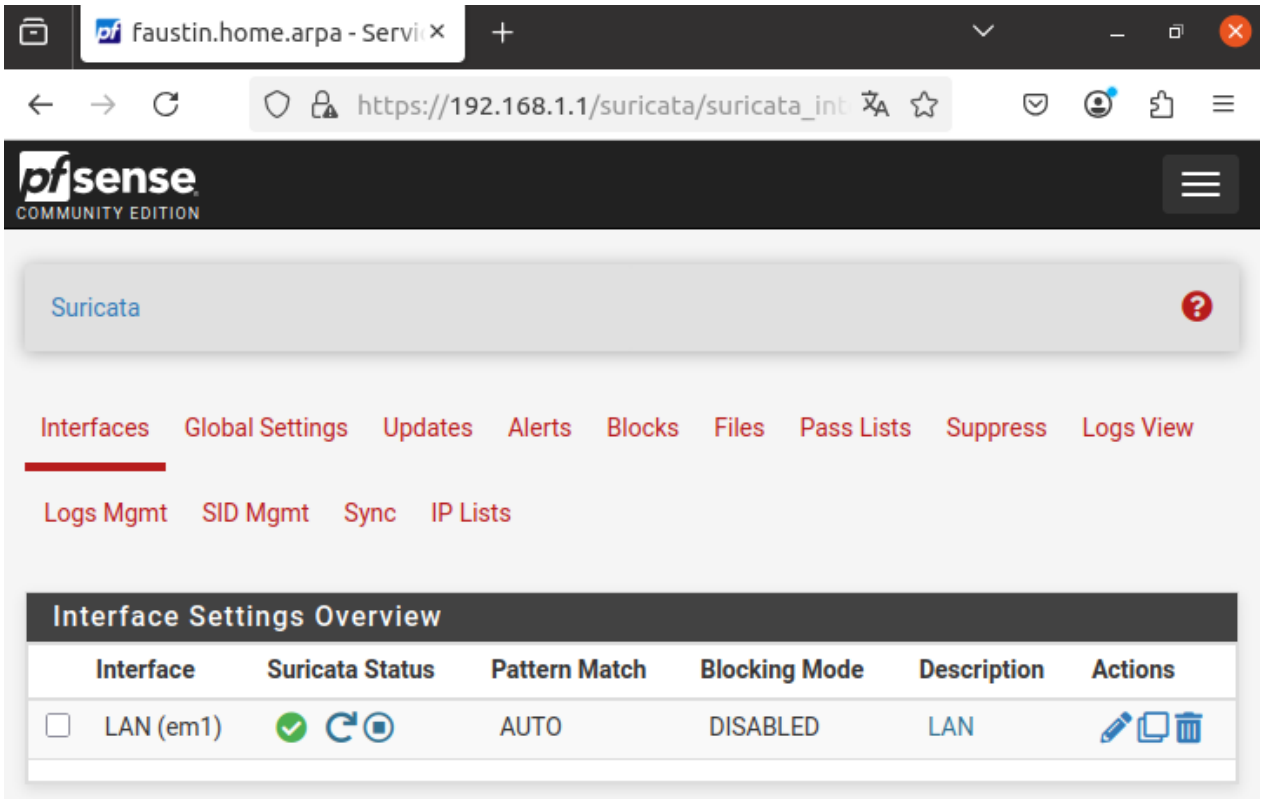
Ces signatures permettent à Suricata de reconnaître automatiquement : scans Nmap, brute force, exploitations connues.



4. Démarrage de Suricata

Services → Suricata → Interfaces → Activer Suricata sur le LAN.

Vérification : Suricata est actif et analyse le trafic réseau en temps réel.



5. Génération d'une attaque : Scan Nmap

Depuis Kali Linux, exécution d'un scan SYN vers Ubuntu (192.168.1.10) :nmap -sS 192.168.1.10

Observation attendue : Suricata détecte cette activité comme suspecte.

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	Gl
04/30/2026 13:38:57	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.1	53	192.168.1.10	43479	1
04/30/2026 13:38:57	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.1	53	192.168.1.10	45087	1
04/30/2026 13:38:57	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.1	53	192.168.1.10	45570	1
04/30/2026 13:38:57	⚠	3	UDP	Generic Protocol	192.168.1.1	53	192.168.1.10	45570	1

7. Simulation d'une attaque avancée : Metasploit

Depuis Kali : lancement de msfconsole puis tentative d'exploitation (ex. SMB).

Retour dans les alertes Suricata : des événements plus critiques apparaissent.

Suricata détecte non seulement les scans simples, mais aussi les comportements liés aux attaques avancées.

```
msf6 > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf6 auxiliary(scanner/smb/smb_login) > set set RHOSTS 192.168.1.20
[!] Unknown datastore option: set.
set => RHOSTS 192.168.1.20
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.1.20
RHOSTS => 192.168.1.20
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser faustin
SMBUser => faustin
msf6 auxiliary(scanner/smb/smb_login) > set SMBPass 1234
SMBPass => 1234
msf6 auxiliary(scanner/smb/smb_login) > run

[*] 192.168.1.20:445      - 192.168.1.20:445 - Starting SMB login bruteforce
[-] 192.168.1.20:445      - 192.168.1.20:445 - Could not connect
[!] 192.168.1.20:445      - No active DB -- Credential data will not be saved!
[*] 192.168.1.20:445      - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.1.20:445      - Bruteforce completed, 0 credentials were successful.
[*] 192.168.1.20:445      - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) >
```

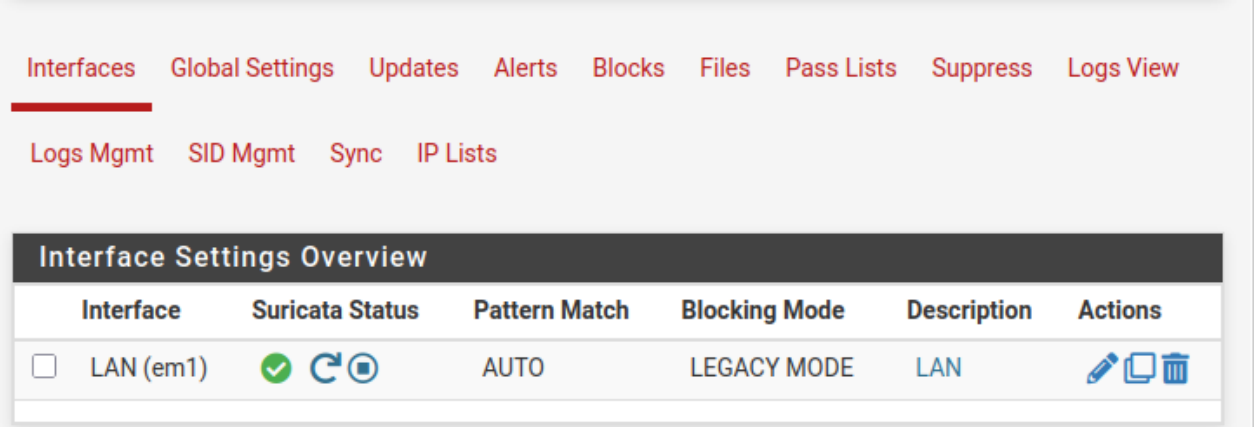
8. Passage en mode blocage (IPS)

Dans la configuration de l'interface LAN de Suricata : activer « Block offenders » → Appliquer.

Test : relancer un scan Nmap depuis Kali.

Résultats attendus : le scan est perturbé ou bloqué, certaines connexions échouent.

Interprétation : passage d'un IDS (détection seule) à un IPS (détection + blocage).



On constate que le scan ne passe plus

```
┌──(faustin㉿teutchueng)-[~]
└─$ sudo nmap -sS 192.168.1.10
sudo: unable to resolve host teutchueng: Temporary failure in name resolution
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-30 08:13 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syste
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.24 seconds
```

9. Explication des concepts clés

Comment Suricata détecte une attaque

Suricata inspecte chaque paquet réseau et le compare à une base de signatures. Si une correspondance est trouvée, une alerte est générée (mode IDS) ou le trafic est bloqué (mode IPS).

Différence entre IDS et IPS

IDS (Intrusion Detection System) : surveille et alerte, mais ne bloque pas.

IPS (Intrusion Prevention System) : surveille, alerte ET bloque le trafic malveillant.

Intérêt des signatures

Les signatures sont des règles décrivant des comportements malveillants connus. Elles permettent à Suricata de reconnaître automatiquement des milliers d'attaques sans intervention humaine.

10. Options avancées de Suricata

Types de règles : règles ET Open (Emerging Threats), règles personnalisées locales.

Niveaux de sévérité : chaque alerte dispose d'un niveau (1 = critique, 3 = faible) permettant de prioriser les incidents.

Filtrage des alertes : possibilité de supprimer les faux positifs via des règles de suppression (suppress list) pour affiner la détection.

Conclusion

Ce TP a permis de mettre en place une couche d'intelligence réseau au-dessus du pare-feu pfSense. Un pare-feu contrôle les flux ; un IDS/IPS analyse les comportements. Les deux sont complémentaires et constituent la base d'un SOC moderne.